

Exercice 2 — Conception et planification de la sécurité

Objectif : bâtir le plan de sécurité d'HelioMed, l'intégrer dans le cycle de vie du projet, proposer une architecture, planifier les tests et un plan de réponse aux incidents.

Étape 2.1 — Mesures de sécurité justifiées

Sélectionnez vos mesures en vous appuyant sur un référentiel reconnu. Reliez chaque mesure à un contrôle **ISO/IEC 27002:2022** ET à un point du guide d'hygiène **ANSSI**. Minimum 12 mesures couvrant : authentification (MFA), cloisonnement réseau, chiffrement (au repos/en transit), gestion des secrets, journalisation, sauvegardes, durcissement des serveurs, sécurité applicative (OWASP Top 10).

Étape 2.2 — Intégration dans le cycle projet (DevSecOps)

1. Placez chaque mesure sur la timeline du projet (conception → build → run) et identifiez les points de contrôle « go/no-go ».
2. Décrivez concrètement comment vous intégrez la sécurité dans le pipeline Git : hook / job CI qui lance Trivy et un scan de secrets (ex. gitleaks) à chaque commit. Écrivez le fichier de pipeline (.gitlab-ci.yml ou GitHub Actions) — il devra fonctionner en Ex.3.

Étape 2.3 — Architecture de sécurité cible

Produisez un schéma d'architecture (fait avec draw.io / diagrams.net, exporté en image) montrant : segmentation réseau (DMZ frontale / zone applicative / zone données), reverse proxy, WAF, pare-feu et flux autorisés, emplacement des chiffrements, collecte de logs vers le SIEM. Le schéma doit correspondre à ce que vous déploieriez réellement en Ex.3.

Contrainte de cohérence

Les IP/zones du schéma = celles de vos VM. Un schéma générique non raccordé à votre labo est invalidé.

Étape 2.4 — Plan de tests de sécurité

Type de test	Outil	Cible	Critère de réussite
Scan de vulnérabilités web (DAST)	OWASP ZAP	API/front HelioMed	0 alerte High non traitée
Scan dépendances/image (SCA)	Trivy	Image applicative	0 CVE critique restante
Test de config / durcissement	Lynis	VM Linux	Score Lynis en hausse documentée
Test réseau	Nmap	Les 2 VM	Aucun port inutile ouvert

Étape 2.5 — Plan de réponse aux incidents (ébauche)

- Définissez les rôles (qui décide, qui agit, qui communique), les niveaux de gravité, et les 6 phases NIST (préparation, identification, confinement, éradication, rétablissement, retour d'expérience).
- Précisez, pour HelioMed, l'obligation RGPD de notifier la CNIL sous 72 h en cas de violation de données de santé.

Livrable Ex.2 (à déposer 17h30)

Plan de sécurité (mesures ↔ ISO 27002 ↔ ANSSI), timeline DevSecOps, fichier de pipeline CI, schéma d'architecture exporté en image, plan de tests, ébauche du plan de réponse, logbook individuel.